

VendorSentinel

Always-On AI-Powered Third-Party Vendor Risk Intelligence

Continuous third-party security sweeps using Bright Data crawlers and AI scoring engines.

■■ Track 3: Web Data & Compliance | Bright Data Hackathon 2026

Team Members: Hafiz Abdul Rehman • Meer Hamza • Sayyam Akram

Live App: <https://vendor-sentinel.vercel.app/>

GitHub: <https://github.com/Abdul-Insighht/VendorSentinel.git>

The Third-Party Vendor Risk Crisis

Outdated assessment models expose modern enterprises to silent, catastrophic supply-chain threats.

\$4.5M

Average Cost of a Breach
IBM Cost of a Data Breach Report

■ Verifiable Case Studies

In 2021, the SolarWinds supply chain attack compromised over 18,000 organizations including the US Treasury. Their database credentials lay exposed on public GitHub as 'solarwinds123' for thirteen months completely unnoticed. In 2024, the Snowflake breach exposed data from 165 major enterprises (including AT&T, Ticketmaster, and Santander Bank). The fault sat entirely at the vendor level, but the financial damage landed squarely on their customers.

The Vulnerability Problem

Every modern enterprise outsources critical parts of its infrastructure to third-party vendors. Your payment processors hold credit card databases, cloud providers house sensitive customer records, and authentication providers govern corporate login directories. These vendors sit at the core of your security posture, yet security administrators possess zero real-time visibility into their daily operational health.

The Signal Paradox

Major supply-chain breaches never happen without warning. Factual signals are always public beforehand—scattered across paste boards, code repositories, and job vacancies. SolarWinds had its public credentials leaked, Snowflake's customer session keys circulated on forums weeks prior, and corporate hiring spikes occurred. Nobody was systematically watching.

The Obsolete Checklists

The current standard security solution is a self-attested PDF questionnaire sent once a year. The vendor simply checks 'Yes, we are secure' and files it away. In 2026, this static method is completely inadequate to detect live threats, configuration gaps, and active leakage cycles.

The Technical Barriers to Vendor Audits

Why manual security monitoring and standard scripts fail to protect corporate ecosystems.

CAPTCHAs & IP Bans	Public sharing platforms like Pastebin and GitHub actively protect their data from scrapers. Standard automated scrapers are instantly blocked by CAPTCHAs, dynamic browser challenges, and IP address bans.
Rate Limits & Scraper Blocks	Hiring platforms like LinkedIn enforce strict rate limits and dynamically check requests for bot behavior, making it technically impossible for a standard script to monitor even a small portfolio of vendors.
JavaScript Rendering Walls	Morale review platforms and trust blogs utilize heavy JavaScript frameworks that render data dynamically. Standard HTTP clients only fetch static raw HTML, completely missing the actual content text.
Scale & Bandwidth Overload	Even if a security team attempted manual daily check loops across 50 vendors on these platforms, the sheer operational overhead and time required would completely overwhelm their analytical bandwidth.

The Solution: Bright Data Powered Pipeline

Defeating anti-bot shields to construct an automated third-party risk intelligence pipeline.

Bright Data Infrastructure

VendorSentinel completely solves these technical barriers by leveraging Bright Data's global proxy and browser automation network. Bright Data provides the only enterprise infrastructure capable of reliably bypassing bot protections, resolving CAPTCHAs, and fetching JavaScript-heavy pages at scale. The system runs fully autonomously—checking every registered vendor across 4 signal dimensions every 6 hours, storing findings, and feeding them to our AI agent.

The Four Signal Dimensions

- **Signal One (News & Media):** Utilizes Bright Data SERP API to index search results for published breaches, regulatory fines, and GDPR class action lawsuits.
- **Signal Two (Exposed Leaks):** Employs Web Unlocker to search public code repos and Pastebin for domain password/API key exposures.
- **Signal Three (Hiring Spikes):** Integrates Web Scraper API to track security recruitment spikes on LinkedIn.
- **Signal Four (Reputation checks):** Runs Scraping Browser CDP to crawl posture patches and employee reviews.

Signal One — News & Public Media Monitoring

Indexing global search engine queries in real-time for security-relevant public disclosures.

SERP API

Real-Time Search Results

■ Indexed Keywords

- 'data breach'
- 'ransomware attack'
- 'security incident'
- 'regulatory fine'
- 'GDPR violation'
- 'class action'

Operational Framework

The first layer of defense uses Bright Data's **SERP API** to query Google, Bing, and major search engines dynamically for each onboarded vendor. By combining the vendor's company name with threat keywords (GDPR violation, ransomware, data leak, lawsuit), it parses organic search items in real-time and normalizes them into structured JSON arrays containing title, publish date, snippet, and source link.

Impact & Severity Classification

This layer catches anything that has already reached the public domain. It verifies headlines, publication dates, and legal source URLs. The system automatically classifies threat severity based on keyword categories—for instance, 'ransomware' or 'cyberattack' matches trigger critical ratings, while 'patch' or 'vulnerability' issues trigger warning flags, providing a complete baseline check.

Signal Two — Credential Leak Detection

Scraping public paste boards and public GitHub code commit endpoints for exposed data.

Bypassing Anti-Bot Blocks	Public repositories and paste boards aggressively block automated crawler requests with CAPTCHAs, IP bans, and browser fingerprinting. Bright Data Web Unlocker proxy handles all this transparently: it automatically rotates residential IP addresses, solves CAPTCHAs, and handles challenges to return full raw HTML text.
Target Search Query	VendorSentinel queries these secure sites searching for vendor-specific leak patterns. It combines the vendor's primary domain name with keywords like `password`, `api_key`, `token`, `secret`, and private key blocks (-----BEGIN RSA PRIVATE KEY-----).
Critical Alerts & Verification	If any search results match these patterns alongside a vendor's domain name, it indicates direct exposure of active authentication secrets and is flagged as a critical-priority risk. This provides a powerful, proactive warning of potential breach conditions.
Ethical & Legal Compliance	This scanning process is entirely legal and compliant. Every piece of code or text scanned is already publicly visible on the open web. The system simply automates in real-time what a manual security analyst would do—catching exposures in days instead of months.

Signal Three — Hiring Distress Detection

Tracking LinkedIn security recruitment metrics to uncover silent internal crisis periods.

Web Scraper API

LinkedIn Job Board Aggregator

■ Tracked Roles

- 'CISO' / Security Director
- Incident Response Engineer
- SOC Security Analyst
- Threat Intelligence Analyst
- Application Security Architect

LinkedIn Datasets Scrapes

When an enterprise is quietly dealing with a serious security failure or a breach, one of the most reliable early warning indicators is a sudden, urgent spike in security recruitment. Bright Data's **Web Scraper API** provides robust, pre-built scrapers for LinkedIn company pages. We query the vendor's job board to fetch recent job listings, avoiding custom scrapers.

Hiring Spike Analytics

The system filters job listings for security-specific roles and calculates the baseline volume against the previous 30 days. An abnormal recruitment spike (e.g. 5 vacancies last month vs 15 vacancies now) is flagged. This represents an active attempt to rebuild threat mitigation teams, providing a clear signal of security concerns weeks before any public news.

Signal Four — Vendor Health & Reputation

Crawling Glassdoor morale ratings and corporate trust blogs via Playwright CDP.

Playwright CDP Connection	The fourth layer utilizes Bright Data's Scraping Browser , a full Playwright-based browser that natively handles JS-heavy pages, dynamically rendering content and transparently handling anti-bot scripts.
Glassdoor Employee Reviews	We crawl the vendor's Glassdoor reviews looking for language clusters indicating organizational chaos. We filter for terms like 'mass layoffs', 'leadership departures', and 'restructuring' which correlate with corporate distress.
Corporate Security Blogs	The system crawls the vendor's own security and engineering blogs. A sudden, unusual increase in security advisory posts or defensive updates suggests they are actively remediating an unpublicized threat.
Morale & Posture Analysis	None of these signals is conclusive on its own. But when a vendor shows negative reviews, an unusual security hiring surge, and a flurry of defensive blog posts in a 30-day window, the combination creates a clear warning pattern.

The AI Risk Scoring Engine

Harnessing Claude via MCP to synthesize raw web signals into evidence-backed audits.

GPT-4o-mini

Generative AI Scoring Engine

■ AI Output Elements

- Risk Score (1-10)
- Risk Level (Low-Critical)
- Detailed Reasoning Logs
- Mitigation Playbooks

Multi-Source AI Synthesis

After all 4 signal vectors are collected, they are normalized and passed to the **AI Scoring Engine** (GPT-4o-mini). Instead of simple rule-based metrics, the AI reasons over the combined signals, weighs their severities, and delivers a structured, evidence-backed report. It provides a numeric risk score (1.0-10.0), a plain-English explanation, and a step-by-step mitigation playbook for the security team.

Example AI Output Report

This vendor scores 8.2 out of 10. Three signals are contributing to this score. First, a string matching the vendor domain combined with the word "api_key" was found on Pastebin on May 22nd. Second, the vendor has posted eleven security job openings in the past two weeks, a 450% spike. Third, fourteen Glassdoor reviews contain language related to sudden leadership changes. Recommended action: contact relationship manager immediately andBegin qualifying an alternative vendor.

Strategic Business Value & Market Scope

Enterprise market potential, capital risk mitigation, and SaaS monetization channels.

Monetization Channel	Operational Implementation	Commercial Enterprise Value
SaaS Subscription	Monthly tier licenses based on active vendor counts and database scan intervals.	Enables predictable annual recurring revenue (ARR) from small to enterprise clients.
Secure BI APIs	Dedicated endpoints to integrate risk scores into tools like Power BI or ServiceNow.	Drives deep ecosystem integration, increasing product stickiness and enterprise scaling.
Audit Report Exports	Cryptographically signed compliance reports ready for external board audits.	Provides transactional revenue channels, capturing extra value from audit cycles.

Originality & Unique Selling Proposition

Comparing VendorSentinel to legacy checklists and static security database products.

Dynamic Web Crawling	Conventional database products (e.g. BitSight, SecurityScorecard costing \$50k-\$200k/year) rely on static, historical registries that fail to perform real-time monitoring. VendorSentinel runs continuous 6-hour sweeps across the live web.
Deep Anti-Bot Bypassing	Standard compliance tools cannot reliably bypass anti-bot shields. VendorSentinel harnesses Bright Data's global proxy and automation networks to defeat CAPTCHAs, rate limits, and JS rendering blocks.
Factual AI Integrity	Standard LLMs frequently hallucinate metrics. Our AI Scoring Engine uses structured prompts and aggregates normalized evidence logs, creating audit trails with full facts provenance.
Evidence Playbooks	Instead of generic dashboards, the system delivers structured reasoning summaries and custom-compiled playbooks indicating the exact mitigation steps required.

Strategic Execution Roadmap

A 4-phase scaling plan from current production MVP to full enterprise integrations.

Phase	Execution Targets	Technical Milestones
Phase 1: Production MVP	Complete implementation of 4 Bright Data collectors + FastAPI async backend + React 19 UI dashboard.	Fully deployed on Vercel/Render, dynamic radar, node status health checker, and SQLite WAL database.
Phase 2: SSO & Granular Auth	granular security boundaries, multi-tenant directory authentication, and customizable alert rules.	SAML/OAuth SSO integration, multi-tenant databases partition, and Slack/Teams webhooks integration.
Phase 3: DB Connectors	Developing native enterprise connectors to pull vendor lists automatically from cloud sources.	Connectors to Snowflake, BigQuery, and Salesforce APIs to maintain dynamic, live vendor pipelines.
Phase 4: AI Governance	Granular AI model governance and cryptographic audit trail logging.	Integration with dedicated prompt firewalls (e.g. Lobster Trap) for cryptographic audit trails.

The Complete Technical Stack

Enterprise-ready open source frameworks and cloud integration layers.

Language & Hosting

- Language: Python 3.11
- Server: FastAPI Async served by Uvicorn
- DB: SQLite WAL (aiosqlite)
- Host: Render.com Container

■ Frontend Engine

- Framework: React 19
- Styling: Custom Vanilla CSS
- Bundler: Vite
- Host: Vercel Cloud Network

Bright Data Pipeline Layer

- **SERP API:** Queries Google and Bing search engine results to index public media news.
- **Web Unlocker:** Bypasses bot protections and CAPTCHAs to scan Pastebin.
- **Web Scraper API:** Pulls structured LinkedIn job board listings without custom code.
- **Scraping Browser:** Headless Playwright Chromium CDP sessions to audit compliance blogs.

AI & Security Governance

- **AI/ML API:** GPT-4o-mini chat completion endpoints to generate structured assessments.
- **Environment Protection:** Dotenv environment variables (.env.example) safeguarding API keys.
- **Windows Loop Policy:** Custom Proactor loop policy handling win32 subprocess limitations.

Interactive Demonstration Guide

Step-by-step walkthrough to test every platform module live.

1. Open Welcome Gate	Navigate to your live URL <code>https://vendor-sentinel.vercel.app</code> . Read the problem brief, and click Enter Security Dashboard → to bypass the gate.
2. Onboard Figma (Low Risk)	Go to <code>/vendors</code> , click + Add Vendor , and onboard <code>`Figma, Inc.`</code> (domain: <code>`figma.com`</code>) with <code>`Low`</code> sensitivity. Scanners verify clean compliance audit playbooks, scoring 2.0 Low Risk .
3. Onboard Auth0 (Critical)	Onboard <code>`Auth0 by Okta`</code> (domain: <code>`auth0.com`</code>) with <code>`Critical`</code> sensitivity. Exposed credential scans match warnings on paste boards, and the AI Engine generates a 8.0 Critical Risk rating.
4. Run Threat sweeps	Navigate to <code>/scan`</code> . Verify the spinning golden radar sweeper, concentric active wave rings, and pulsing threat blips. Trigger a scan and watch history records compile and poll live.
5. Verify Node Health	Navigate to <code>/settings`</code> . Verify the golden threshold slider operates correctly, and see all Bright Data Nodes marked with pulsing green active indicators.

VendorSentinel: Security with Certainty

Redefining how enterprises validate, reconcile, and monitor third-party cybersecurity postures.

■ Always-On Sweeping

Continuous 6-hour sweeps across paste boards, search engines, compliance blogs, and talent listings instead of stale PDF checklists.

■■ Deep Bright Data Integration

Defeats bot blocks and CAPTCHAs natively using SERP API, Web Unlocker, Web Scraper, and Scraping Browser.

■ Evidence-Backed AI Playbooks

Generates clean risk grades (1.0-10.0), detailed structural justifications, and custom mitigation playbooks under a robust offline rule-based fallback framework.

“VendorSentinel doesn't just scan vendors — it secures the supply chain.”